

WEB VAPT EVIDENCE FILE DOCUMENTATION

15-reflected-xss-alert-popup.png

Field	Details
Project	Enterprise Security Assessment Lab
Module	Sub-Project 1 - Web Application VAPT
Evidence Row	20 - Reflected XSS
Evidence File	15-reflected-xss-alert-popup.png
Result Type	XSS validation
Prepared For	GitHub portfolio documentation

Document Purpose

This PDF documents one specific evidence file from the Web VAPT evidence table. It embeds the actual screenshot, explains what the screenshot proves, maps it to the methodology, and records professional interpretation, risk, remediation, and redaction guidance for GitHub publication.

1. Embedded Evidence Screenshot

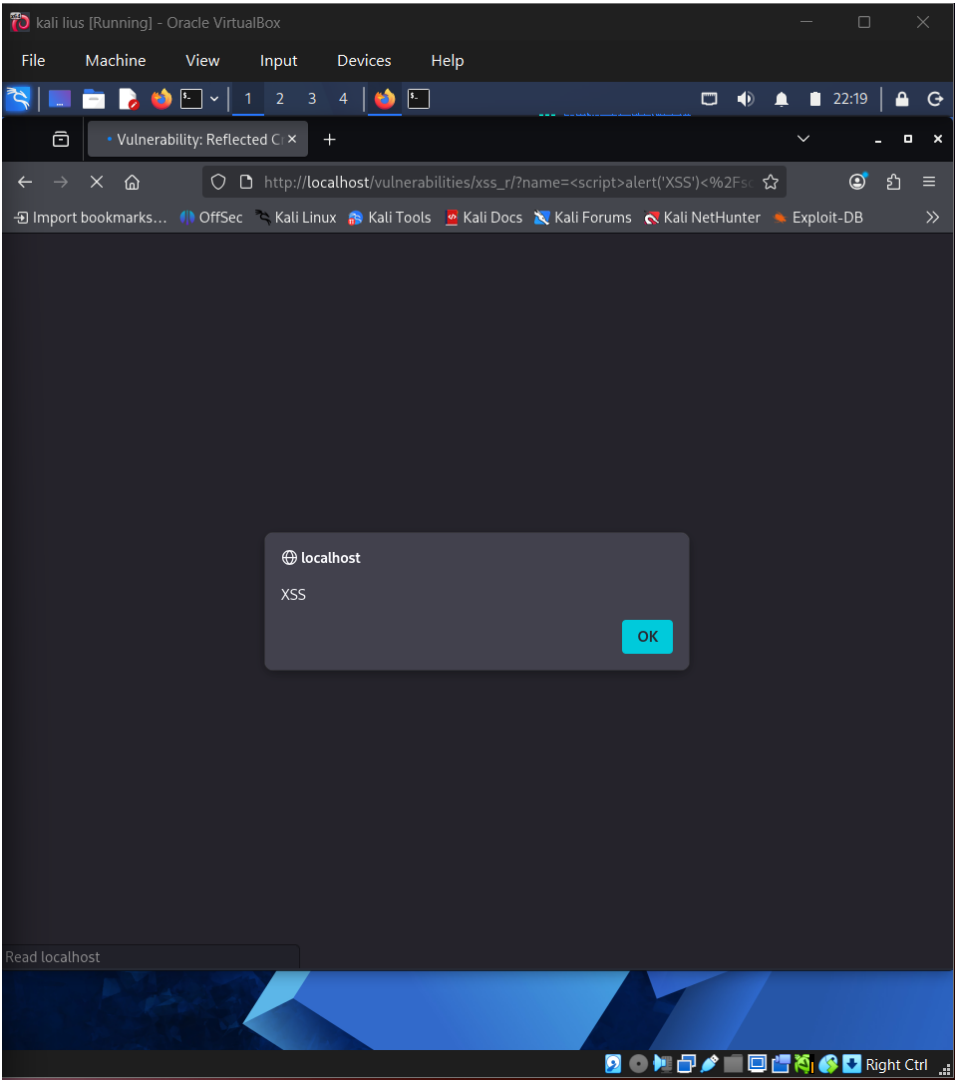


Figure 1 - Actual screenshot evidence: 15-reflected-xss-alert-popup.png

What this screenshot proves

The screenshot shows a browser JavaScript alert triggered on localhost, confirming reflected XSS behaviour in the lab.

2. Evidence Context

Area	Value
Testing Phase	Reflected Cross-Site Scripting Validation
Tool / Component	Browser / DVWA
Objective	Confirm reflected JavaScript execution from user-controlled input in the DVWA reflected XSS module.
Result Type	XSS validation

3. Command / Workflow Used

Payload: `<script>alert("XSS")</script>`
Submit payload through reflected XSS input or URL parameter

The commands or workflow above represent the evidence-producing action. Placeholders such as , , or should be used in public documentation instead of live secrets or private infrastructure details.

4. Professional Interpretation

The screenshot shows a browser JavaScript alert triggered on localhost, confirming reflected XSS behaviour in the lab.

This evidence should be treated as a supporting artifact, not as a standalone finding by itself. In a professional report, the screenshot supports a specific testing phase, validates an observation, and strengthens reproducibility when paired with methodology and remediation guidance.

5. Security Risk / Why It Matters

Reflected XSS can enable phishing, browser-side attacks, and session theft if cookies are not protected.

For this portfolio project, the risk is described in a real-world context while clearly noting that the target was an authorized DVWA/local lab environment. This avoids exaggerating lab results as production impact.

6. Recommended Remediation / Defensive Control

Perform context-aware output encoding, sanitize input, use CSP, and set cookies with HttpOnly and SameSite.

7. GitHub Redaction Requirements

URL parameters containing sensitive values, cookies, and browser history/bookmarks.

Before pushing to GitHub, confirm that screenshots do not expose cookies, session IDs, credentials, hashes, cracked passwords, private IPs, internal file paths, or any secret values. If the screenshot already contains sensitive information, blur or crop it before upload.

8. GitHub README Link Snippet

```
[Open Evidence PDF](./reports/evidence-file-documentation-with-screenshots/20_15-reflected-xss-alert-popup_evidence_documentation.pdf)
```

Legal and Ethical Note

This evidence documents authorized testing against an intentionally vulnerable local lab target. The techniques described must not be used against public or third-party systems without explicit permission.